CORE SECURITY POLICIES

Futer Exp | GRC Program

Version 1.0 | March 2026 | Classification: Confidential

Document Owner	Approved By	Review Cycle	Effective Date
CISO	Executive Committee	Annual	March 2026

Policies Contained in This Document

Policy	Title	Regulatory Basis
POL-01	**Access Control Policy**	ISO 27001 A.8.2–8.5 · NIST CSF PR.AA · NIS2 Art.21
POL-02	**Data Protection Policy**	GDPR Art.5,24,32 · ISO 27001 A.8.12,8.24 · NIS2 Art.21 · DORA Art.9

Both policies are mandatory and apply to all Futer Exp employees, contractors, consultants, and third parties with access to Futer Exp systems, data, or facilities. Non-compliance may result in disciplinary action up to and including termination of employment or contract.

POL-01

ACCESS CONTROL POLICY

Futer Exp | Version 1.0 | March 2026

Policy ID	POL-01
Policy Owner	CISO
Applies To	All employees, contractors, and third parties with system access
Regulatory Basis	ISO 27001:2022 A.8.2–A.8.5 · NIST CSF PR.AA · NIS2 Art.21
Last Reviewed	March 2026
Next Review	March 2027

1. Purpose

This policy establishes the rules and requirements for controlling access to Futer Exp information systems, data, and facilities. The goal is to ensure that access is granted only to authorized individuals, limited to what is necessary for their role, and revoked promptly when no longer required.

2. Scope

This policy applies to:

- All information systems owned or operated by Futer Exp, including cloud environments (AWS), SaaS applications, internal networks, and collaboration tools
- All users: full-time employees, part-time staff, contractors, consultants, interns, and authorized third parties
- All access types: physical, logical, remote, and privileged

3. Principles

All access decisions at Futer Exp are governed by the following principles:

Requirement	Detail
Least Privilege	Users are granted the minimum access rights necessary to perform their job function. No access is granted by default.
Need to Know	Access to sensitive data is restricted to individuals with a clear business need. Data classification drives access decisions.
Separation of Duties	No single individual controls an entire critical process. Key functions are split across roles to reduce insider risk.
Zero Trust	Access is never implicitly trusted based on network location. All access requests are authenticated and authorized explicitly.
Accountability	All access events are logged. Users are accountable for all actions taken under their credentials.

4. Access Management Requirements

4.1 Provisioning

Access must be formally requested and approved before it is granted:

- All access requests must be submitted to IT Operations and approved by the user's line manager
- Access is provisioned based on the user's role. Standard role profiles are defined for common job functions
- Privileged access (admin, root, elevated permissions) requires additional approval from the CISO
- Third-party access must be approved by the Risk Manager and documented in the Vendor Register

4.2 Authentication

Requirement	Detail
Password Minimum Length	Minimum 12 characters. Combination of upper/lowercase, numbers, and symbols required.
Password Reuse	Last 12 passwords cannot be reused.
Multi-Factor Authentication (MFA)	Mandatory for all accounts. Required for: remote access, cloud consoles (AWS), email, SaaS tools, and all privileged accounts.
Single Sign-On (SSO)	SSO used where available to reduce credential sprawl. Federated identity preferred for SaaS applications.
Session Timeout	Workstation auto-lock after 5 minutes of inactivity. Remote sessions expire after 30 minutes idle.
Shared Accounts	Prohibited. Every user must have a unique individual account. Service accounts are documented and owner-assigned.

4.3 Privileged Access

Privileged accounts (system administrators, database administrators, cloud IAM admins) are subject to enhanced controls:

- Privileged accounts must be separate from standard user accounts, no dual-use
- Privileged access must use MFA at every login without exception
- All privileged actions must be logged and retained for a minimum of 12 months
- Just-In-Time (JIT) access is the target model standing privileged access should be eliminated where technically feasible
- Privileged accounts are reviewed quarterly by IT Operations and the CISO

4.4 Remote Access

Remote access to Futer Exp systems is permitted only under the following conditions:

- VPN connection is mandatory for accessing internal systems from outside the office network
- Split-tunnelling is disabled, all traffic must route through the VPN when connected
- Remote access is logged and monitored by IT Operations
- Personal (unmanaged) devices may not be used to access classified or restricted data without express CISO approval
- Remote access for third parties is time-limited and scoped to the minimum required access

4.5 Access Reviews

Access rights are reviewed on the following schedule:

Access Type	Review Frequency	Responsible Party
Standard user access	Quarterly	IT Operations
Privileged access	Quarterly	CISO + IT Operations
Third-party access	At each contract renewal	Risk Manager
Cloud IAM roles (AWS)	Monthly	IT Operations

4.6 Deprovisioning

Access must be revoked promptly when it is no longer required:

Trigger Event	Revocation Deadline	Responsible Party
Employee resignation / termination	**Same day (prior to departure)**	HR + IT Operations
Role change / transfer	Within 5 business days	Line Manager + IT Operations
Contract expiry (third party)	**Day of contract end**	Risk Manager + IT Operations
Project completion	Within 24 hours of project close	Project Owner + IT Operations

5. Prohibited Activities

The following are strictly prohibited under this policy:

- Sharing credentials or allowing another person to use your account
- Attempting to access systems, data, or areas for which you are not authorized
- Using personal email or cloud storage to transfer Futer Exp data
- Installing unauthorized software or tools on Futer Exp systems
- Bypassing or disabling security controls (VPN, MFA, endpoint protection)
- Storing Futer Exp credentials in unsecured locations (unencrypted files, sticky notes, personal password managers without CISO approval)

6. Exceptions

Exceptions to this policy require written approval from the CISO. All exceptions must be documented with a business justification, compensating controls, and a defined expiry date not exceeding 90 days. Exceptions are reviewed at the next quarterly access review.

7. Violations & Enforcement

Violations of this policy are treated as a disciplinary matter. Depending on severity, consequences may include formal warning, suspension of access, termination of employment or contract, or referral to legal authorities where criminal activity is suspected.

POL-02

DATA PROTECTION POLICY

Futer Exp | Version 1.0 | March 2026

Policy ID	POL-02
Policy Owner	CISO / Data Protection Officer (DPO)
Applies To	All employees, contractors, and third parties handling Futer Exp data
Regulatory Basis	GDPR Art.5,24,32 · ISO 27001:2022 A.8.12, A.8.24 · NIS2 Art.21 · DORA Art.9
Last Reviewed	March 2026
Next Review	March 2027

1. Purpose

This policy defines how Futer Exp protects the confidentiality, integrity, and availability of all data it processes, whether belonging to the company, its clients, employees, or third parties. It establishes the minimum standards for data handling, storage, transfer, and disposal, and ensures compliance with applicable data protection regulations.

2. Scope

This policy applies to all data processed by or on behalf of Futer Exp, including:

- Personal data (any information relating to an identified or identifiable natural person)
- Financial and commercial data
- Operational and technical data
- Data processed by third parties under contract with Futer Exp
- Data in all formats: digital, physical, and transmitted

3. Data Classification

All data must be classified upon creation or receipt. Classification determines handling requirements:

Level	Classification	Examples	Default Handling
L1	**Restricted**	PII, health data, authentication credentials, encryption keys, legal privileged documents	Encrypt at rest & in transit. Access on strict need-to-know. No cloud storage without CISO approval.
L2	**Confidential**	Financial reports, contracts, business strategy, employee records, vendor agreements	Encrypt in transit. Role-based access. Internal use only. Do not share externally without approval.
L3	**Internal**	Internal policies, project documentation, meeting notes, internal announcements	Accessible to all Futer Exp staff. Not for external distribution. No encryption required internally.
L4	**Public**	Marketing materials, published reports, website content, press releases	No restrictions. May be shared freely.

4. Data Protection Principles

Futer Exp processes all personal data in accordance with the following GDPR principles (Art. 5):

- Lawfulness, fairness, and transparency, data is processed on a valid legal basis and individuals are informed
- Purpose limitation, data is collected for specified, explicit, and legitimate purposes and not processed incompatibly
- Data minimisation, only data that is necessary for the stated purpose is collected and retained
- Accuracy data is kept accurate and up to date; inaccurate data is corrected or deleted without delay
- Storage limitation data is not retained longer than necessary; retention periods are defined per data type
- Integrity and confidentiality data is protected against unauthorized access, loss, or destruction
- Accountability; Futer Exp can demonstrate compliance with these principles at any time

5. Data Handling Requirements

5.1 Encryption

Requirement	Detail
Data at Rest	All Restricted (L1) and Confidential (L2) data must be encrypted at rest using AES-256. AWS S3 SSE-KMS is the standard for cloud storage.
Data in Transit	TLS 1.2 or higher is mandatory for all data transmitted across networks. Unencrypted transmission of L1/L2 data is prohibited.
Portable Media	Data stored on USB drives, laptops, or other portable devices must be encrypted. Unencrypted portable media is prohibited for L1/L2 data.
Email	Restricted data must not be transmitted via unencrypted email. Use secure file sharing platforms approved by IT Operations.
Key Management	Encryption keys are managed via AWS KMS. Keys must be rotated annually. Key access is logged via CloudTrail.

5.2 Data Storage

The following rules apply to all data storage:

- Data must be stored only in approved storage locations (AWS S3, approved SaaS tools, or Futer Exp-managed systems)
- Personal data belonging to EU data subjects must not be stored outside the European Economic Area without a valid transfer mechanism (Standard Contractual Clauses, adequacy decision)
- Personal devices (personal phones, home computers) must not be used to store Futer Exp Restricted or Confidential data
- Shadow IT (unapproved tools and storage) is prohibited for data at L1 or L2 classification

5.3 Data Retention & Disposal

Data Type	Retention Period	Disposal Method	Owner
Employee personal data	Duration of employment + 5 years	Secure deletion (DoD 5220.22-M)	HR / DPO
Client / customer data	Per contract + 7 years	Secure deletion + certificate	Risk Mgr / DPO
Financial records	7 years (EU regulatory)	Secure deletion	Finance / DPO
Security logs / SIEM	12 months minimum	Automated purge after retention period	IT Operations
Vendor contracts / DPAs	Duration + 7 years	Secure deletion	Legal / Risk Mgr
Recruitment / CV data (unsuccessful)	6 months post-decision	Deletion from all systems	HR / DPO

Physical documents containing L1 or L2 data must be shredded using cross-cut shredders. Standard waste bins are prohibited for printed sensitive data.

5.4 Data Transfers

Transfers of personal data to third parties require:

- A signed Data Processing Agreement (DPA) that meets GDPR Article 28 requirements
- Verification that the recipient has adequate security controls (via Vendor Questionnaire)
- For transfers outside the EEA: a valid transfer mechanism (Standard Contractual Clauses or adequacy decision)
- CISO approval for any transfer of Restricted (L1) data to external parties

6. Individual Rights (GDPR)

Futer Exp respects and facilitates the rights of individuals whose personal data it processes:

Right	Description	Response Deadline
Right of Access (SAR)	Individuals may request a copy of all personal data held about them.	30 days
Right to Rectification	Individuals may request correction of inaccurate personal data.	30 days
Right to Erasure	Individuals may request deletion of personal data where there is no legal basis for retention.	30 days
Right to Restrict Processing	Individuals may request that processing is limited in certain circumstances.	30 days
Right to Data Portability	Individuals may request their data in a structured, machine-readable format.	30 days
Right to Object	Individuals may object to processing based on legitimate interests or direct marketing.	Immediate stop + 30 days review

All data subject requests are handled by the DPO. Requests must be acknowledged within 3 business days and fulfilled within the statutory deadline.

7. Personal Data Breach Response

In the event of a confirmed or suspected personal data breach, the following procedure applies:

- **Immediate containment, isolate affected systems and preserve evidence**
  - IT Operations must be notified within 1 hour of discovery
- **Assessment, determine the scope, nature, and categories of data affected**
  - CISO and DPO must be informed within 4 hours
- **Regulatory notification, if the breach poses a risk to individuals**
  - Notify relevant supervisory authority (e.g., AEPD in Spain, BfDI in Germany) within 72 hours (GDPR Art. 33)
  - Notify affected individuals without undue delay if high risk to their rights (GDPR Art. 34)
  - For significant ICT-related breaches: notify per NIS2 Art. 23 and DORA Art. 19 timelines
- **Documentation, all breaches must be documented in the breach register regardless of regulatory threshold**
- **Post-incident review, root cause analysis and control improvements within 30 days**

8. Third-Party Data Processing

All third parties processing personal data on behalf of Futer Exp must:

- Sign a GDPR-compliant Data Processing Agreement before processing begins
- Complete the Futer Exp Vendor Security Questionnaire and meet minimum security standards
- Process personal data only on documented instructions from Futer Exp
- Notify Futer Exp of any sub-processors before engagement and obtain prior written approval
- Return or securely delete all personal data upon contract termination

9. Prohibited Activities

- Processing personal data without a documented lawful basis
- Transferring personal data outside the EEA without a valid transfer mechanism
- Storing L1/L2 data on personal devices or unapproved cloud services
- Sending personal or confidential data via unencrypted email or messaging tools
- Retaining personal data beyond the defined retention period without documented justification
- Accessing personal data of colleagues, clients, or third parties beyond what is required for your role

10. Exceptions & Review

Exceptions to this policy require written approval from the CISO and DPO, with a documented justification and compensating controls. Both policies in this document are reviewed annually and updated upon any material change to applicable regulations or Futer Exp's data processing activities.

11. Contact & Accountability

Role	Responsibility	Contact
CISO	Policy owner; breach escalation; exception approvals	ciso@futerexp.com
Data Protection Officer (DPO)	GDPR compliance; data subject requests; breach notification	dpo@futerexp.com
Risk Manager	Third-party data processor oversight; Vendor Register	risk@futerexp.com
IT Operations	Technical controls; encryption; access provisioning	it@futerexp.com